JS

Jahangir Shukurov | GRC Portfolio

PHASE 0 | CLIENT BASELINE

Company Fact Sheet

Single source of truth for the Orvanta GRC engagement

Client	**Orvanta Payments UAB**
Document ID	**ORV-PROFILE-001**
Version	**1.0**
Date	**7 November 2026**
Classification	**Confidential (sample)**

> Sample engagement — fictional company, prepared for portfolio purposes.

Document control

Field	Value
Document ID	ORV-PROFILE-001
Title	Company Fact Sheet
Version	1.0
Date	7 November 2026
Author	Jahangir Shukurov
Reviewer	Nino Beridze, CISO-designate
Approver	Ugnė Baltrūnaitė, CEO
Classification	Confidential (sample)

Version history

Version	Date	Author	Change
0.1	2 November 2026	Jahangir Shukurov	Working draft from client intake
1.0	7 November 2026	Jahangir Shukurov	Baseline issued for the engagement

Contents

1 Executive summary....3
2 How to use this document....4
3 Company profile....4
3.1 Overview....4
3.2 Products....4
3.3 Why the engagement is happening....4
4 Organization....5
4.1 Organization chart....5
4.2 Named role-holders....6
4.3 Headcount by function and location....6
5 Business processes....7
6 Technology....8
6.1 Network and cloud architecture....8
6.2 System inventory....9
6.3 Data classes....10
6.4 High-level data flows....10
7 Vendors....11
8 Regulatory landscape....11
8.1 Verification status....12
9 Current security maturity....12
9.1 Baseline observations and the attacker's view....13

1 Executive summary

Situation. Orvanta Payments UAB is a Vilnius-based payment institution with 120 people, most of its engineers in Baku, and EUR 3.2 billion in annual payment volume. It grew faster than its security governance. Three enterprise merchant prospects now require ISO/IEC 27001:2022 certification, and DORA already applies.

EUR 21.4M	**EUR 85M**	**640**	**1.6 / 5**
FY2025 net revenue	Average safeguarded funds	Active merchants	Indicative security maturity

Key findings from intake.

- **Strong build, weak governance.** Terraform, encryption and Multi-AZ are in place, but there is no ISMS and no current risk register.
- **Identity is the easiest way in.** Shared admin accounts, five tools without enforced MFA and a 9-day median offboarding time.
- **Attacks would go unnoticed.** There is no SIEM, no scheduled log review and no exercised incident plan.
- **Recovery is unproven.** No full restore is on record, and backups share an account with production.
- **Suppliers are unassessed.** None of the 20 vendors has a documented assessment, including all eight preliminary Tier 1 providers.

Risk in business terms. EUR 2.4M of annual enterprise revenue, equal to 11% of FY2025 net revenue, depends on certification by 30 November 2027. A serious credential compromise could also disrupt payments, delay regulatory reporting and put customer trust and the licence relationship under strain.

Decisions needed from the CEO and Management Board.

#	Decision	Owner	By
1	Sponsor the ISMS program and name it a board-level priority	Ugnė Baltrūnaitė	30 Nov 2026
2	Move the CISO reporting line from the CTO to the CEO (OBS-12)	Ugnė Baltrūnaitė	31 Dec 2026
3	Include the Baku subsidiary in the ISMS scope	Tural Mammadli	15 Jan 2027
4	Commission a QSA review of PCI DSS scope and validation level	Nino Beridze	31 Jan 2027

2 How to use this document

This fact sheet records what the engagement team knows about Orvanta on 7 November 2026. Every later project draws its names, systems, vendors and baseline facts from here. If a fact changes, it changes here first, in the machine-readable master file (data/orvanta_master.json), and the documents are rebuilt.

Prefix	Meaning	Example	Used by
R-	Role and named holder	R-CISO	All projects (owners, RACI, sign-off)
BP-	Business process	BP-05	Projects 2 and 7 (risk, BIA)
SYS-	System	SYS-08	Projects 1, 2, 4 and 7
D-	Data class	D-CHD	Projects 2 and 3
DF-	Data flow	DF-07	Projects 2 and 6
VEN-	Vendor	VEN-02	Projects 2, 6 and 8
REG-	Regulatory or contractual driver	REG-01	Projects 1, 7 and 8
OBS-	Baseline observation from intake	OBS-05	Projects 1, 2 and 5

Reading note. Orvanta and its named people, fictional suppliers, figures and observations are invented. Real vendors appear only as tools Orvanta uses. Nothing here describes the security of those vendors or of any real company.

3 Company profile

3.1 Overview

Attribute	Detail
Legal entity	Orvanta Payments UAB, founded 2018, payment institution licence since 2020
Headquarters	Vilnius, Lithuania
Engineering hub	Baku, Azerbaijan (Orvanta Engineering LLC, wholly owned subsidiary)
Supervisor	Bank of Lithuania
Production hosting	AWS eu-central-1 (Frankfurt), with no production workload outside the EU
Scale, FY2025	EUR 3.2bn payment volume, 640 merchants, 8,200 business accounts, 31,000 active cards, 120 employees

3.2 Products

- **Merchant Payment API.** SEPA Credit Transfer and SEPA Instant pay-ins and payouts, plus card acceptance through a hosted payment page.
- **Business accounts.** IBAN accounts, statements and a web portal for small and mid-sized companies.
- **Card issuing.** Debit cards for account holders. Tessarin handles issuer processing and stores full card numbers.

3.3 Why the engagement is happening

- **Revenue.** 3 enterprise prospects worth EUR 2.4M a year made certification a contract condition.
- **Regulation.** DORA has applied to Orvanta since 17 January 2025, and the ICT risk framework is not yet complete.
- **Scale.** Headcount doubled in three years, and informal controls no longer keep pace with engineering output.

4 Organization

4.1 Organization chart

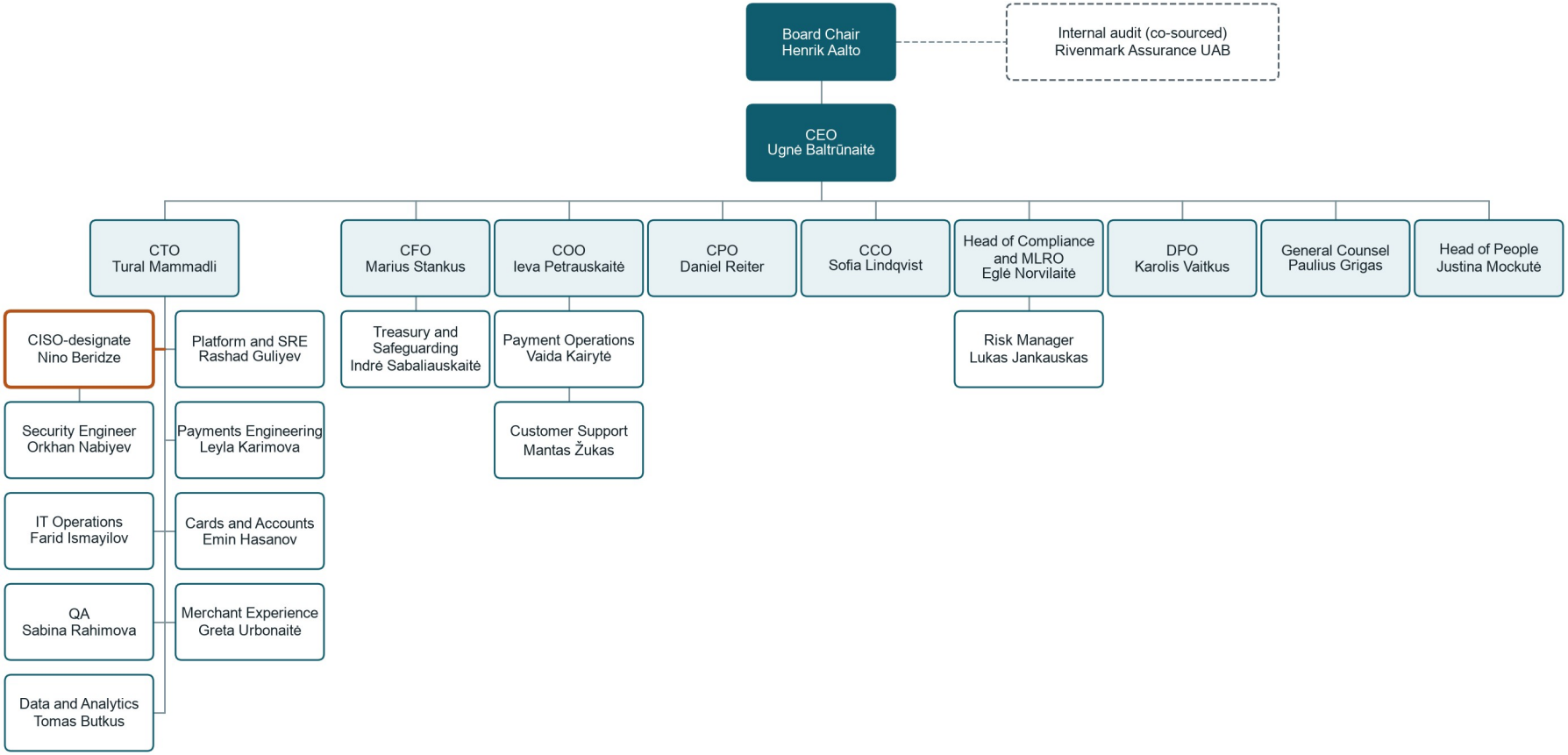


Figure 1: Orvanta reporting lines. The highlighted CISO-designate line is observation OBS-12.

4.2 Named role-holders

Role ID	Role	Holder	Location	Reports to
R-CHAIR	Chair of the Management Board (non-executive)	Henrik Aalto	Remote	Shareholders
R-CEO	Chief Executive Officer	Ugnė Baltrūnaitė	Vilnius	R-CHAIR
R-CTO	Chief Technology Officer	Tural Mammadli	Baku	R-CEO
R-CFO	Chief Financial Officer	Marius Stankus	Vilnius	R-CEO
R-COO	Chief Operating Officer	Ieva Petrauskaitė	Vilnius	R-CEO
R-CPO	Chief Product Officer	Daniel Reiter	Remote	R-CEO
R-CCO	Chief Commercial Officer	Sofia Lindqvist	Remote	R-CEO
R-HCOMP	Head of Compliance and MLRO	Eglė Norvilaitė	Vilnius	R-CEO
R-DPO	Data Protection Officer	Karolis Vaitkus	Vilnius	R-CEO
R-GC	General Counsel	Paulius Grigas	Vilnius	R-CEO
R-HPEOPLE	Head of People	Justina Mockutė	Vilnius	R-CEO
R-CISO	Head of Information Security (CISO-designate)	Nino Beridze	Vilnius	R-CTO
R-SECENG	Security Engineer	Orkhan Nabiyev	Baku	R-CISO
R-RISK	Risk Manager	Lukas Jankauskas	Vilnius	R-HCOMP
R-HSRE	Head of Platform and SRE	Rashad Guliyev	Baku	R-CTO
R-HPAY	Head of Payments Engineering	Leyla Karimova	Baku	R-CTO
R-HCARD	Head of Cards and Accounts Engineering	Emin Hasanov	Baku	R-CTO
R-HMX	Head of Merchant Experience Engineering	Greta Urbonaitė	Vilnius	R-CTO
R-ITOPS	IT Operations Lead	Farid Ismayilov	Baku	R-CTO
R-QA	QA Lead	Sabina Rahimova	Baku	R-CTO
R-DATA	Data and Analytics Lead	Tomas Butkus	Vilnius	R-CTO
R-TREAS	Treasury and Safeguarding Manager	Indrė Sabaliauskaitė	Vilnius	R-CFO
R-PAYOPS	Head of Payment Operations	Vaida Kairytė	Vilnius	R-COO
R-SUPMGR	Customer Support Manager	Mantas Žukas	Vilnius	R-COO

4.3 Headcount by function and location

Function	Lead	Vilnius	Baku	Remote	Total
Executive Office	Ugnė Baltrūnaitė	2	0	0	2
Engineering and IT	Tural Mammadli	8	38	14	60
Information Security	Nino Beridze	1	1	0	2
Product and Design	Daniel Reiter	2	3	2	7
Compliance, AML and Risk	Eglė Norvilaitė	8	0	1	9
Data Protection	Karolis Vaitkus	1	0	0	1
Finance and Treasury	Marius Stankus	7	0	0	7
Operations	Ieva Petrauskaitė	10	0	2	12
Commercial	Sofia Lindqvist	7	0	6	13
People and Legal	Justina Mockutė	5	1	1	7
Total		**51**	**43**	**26**	**120**

5 Business processes

Twelve processes run the business. Criticality here is a working view, which the Business Impact Analysis in Project 7 tests and replaces with measured recovery objectives.

ID	Process	What it does	Owner	Key systems	Criticality
BP-01	Merchant payment acceptance	Accepts merchant API requests and routes SEPA and card payments.	Ieva Petrauskaitė	SYS-01, SYS-02, SYS-20	Critical
BP-02	Payouts and settlement	Settles merchant balances and runs SEPA payout files.	Vaida Kairytė	SYS-02, SYS-23	Critical
BP-03	Business account operations	Opens accounts, posts balances and issues statements.	Ieva Petrauskaitė	SYS-03, SYS-02, SYS-05	Critical
BP-04	Card program operations	Issues, controls and disputes cards through the processor.	Ieva Petrauskaitė	SYS-04, SYS-20	Critical
BP-05	Safeguarding and treasury	Reconciles client funds to safeguarding accounts every day.	Indrė Sabaliauskaitė	SYS-02, SYS-23	Critical
BP-06	Merchant onboarding and KYC	Verifies merchants and owners before activation.	Eglė Norvilaitė	SYS-18, SYS-06, SYS-09	High
BP-07	AML transaction monitoring	Screens transactions and handles alerts and reports.	Eglė Norvilaitė	SYS-18, SYS-02	High
BP-08	Customer support	Handles customer tickets through the outsourced provider.	Mantas Žukas	SYS-19, SYS-06	High
BP-09	Software delivery and change	Builds, tests and deploys code and infrastructure.	Tural Mammadli	SYS-11, SYS-12, SYS-07	High
BP-10	Platform operations	Runs, monitors and restores production services.	Rashad Guliyev	SYS-07, SYS-08, SYS-21, SYS-22	Critical
BP-11	Identity and joiner-mover-leaver	Grants, changes and removes workforce access.	Farid Ismayilov	SYS-13, SYS-14, SYS-17	High
BP-12	Regulatory reporting	Prepares supervisory, AML and incident reports.	Eglė Norvilaitė	SYS-16, SYS-24	High

6 Technology

6.1 Network and cloud architecture

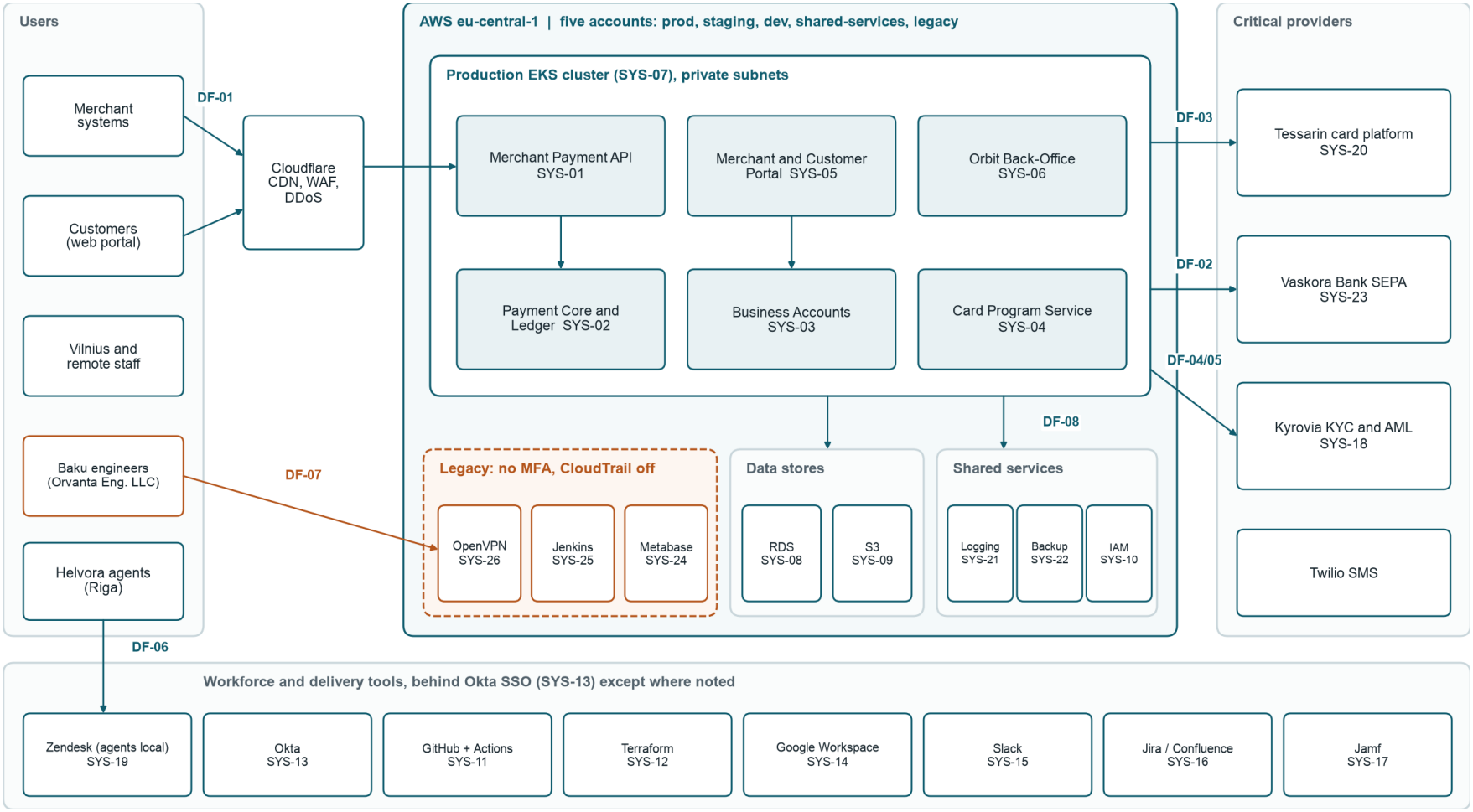


Figure 2: High-level architecture and data flows. Dashed orange marks legacy components outside Okta and the cross-border engineering path.

6.2 System inventory

ID	System	Purpose	Hosting	Owner	Criticality	Data	Access reality
SYS-01	Merchant Payment API	Public REST API for merchant payments	AWS EKS	Leyla Karimova	Critical	D-PAY, D-PII	API keys and mTLS; staff via Okta
SYS-02	Payment Core and Ledger	Orchestration, balances and ledger	AWS EKS and RDS	Leyla Karimova	Critical	D-PAY, D-PII	Service roles; engineer access via kubectl
SYS-03	Business Accounts Platform	IBAN accounts and statements	AWS EKS and RDS	Emin Hasanov	Critical	D-PAY, D-PII	Customer MFA; staff via Okta
SYS-04	Card Program Service	Integration layer to card processor	AWS EKS	Emin Hasanov	Critical	D-CHD, D-PII	Service roles; tokens and truncated PAN only
SYS-05	Merchant and Customer Portal	Web portal for customers	AWS EKS behind Cloudflare	Greta Urbonaitė	High	D-PAY, D-PII	Customer password and TOTP
SYS-06	Orbit Back-Office Console	Internal case, account and fee admin	AWS EKS	Ieva Petrauskaitė	Critical	D-PAY, D-PII, D-KYC	Okta, plus one shared ops-admin login
SYS-07	EKS Production Cluster	Runs all production workloads	AWS eu-central-1	Rashad Guliyev	Critical	D-PAY, D-CRED	AWS SSO; cluster-admin held by 14 engineers
SYS-08	RDS PostgreSQL Production	Primary transactional databases	AWS eu-central-1 (Multi-AZ)	Rashad Guliyev	Critical	D-PAY, D-PII	Bastion and shared DBA credential
SYS-09	S3 Document and Archive Store	KYC files, statements, log archive	AWS eu-central-1	Rashad Guliyev	High	D-KYC, D-PAY, D-LOG	IAM roles; no object-level access review
SYS-10	AWS Organization and IAM	Five accounts and cloud identities	AWS	Rashad Guliyev	Critical	D-CRED	AWS SSO, plus shared admin in legacy account
SYS-11	GitHub and GitHub Actions	Source code and CI/CD	GitHub SaaS	Tural Mammadli	Critical	D-SRC, D-CRED	Okta SAML; long-lived AWS keys in 9 repos
SYS-12	Terraform Infrastructure as Code	Defines AWS infrastructure	GitHub Actions; state in S3	Rashad Guliyev	High	D-SRC, D-CRED	CI role; some applies from laptops
SYS-13	Okta Workforce Identity	SSO and MFA for workforce	Okta SaaS	Farid Ismayilov	Critical	D-HR, D-CRED	Admin MFA enforced; 6 super admins
SYS-14	Google Workspace	Email, documents and shared drives	Google SaaS	Farid Ismayilov	High	D-PII, D-HR, D-FIN	Okta SSO and MFA
SYS-15	Slack	Internal chat and on-call channels	Slack SaaS	Farid Ismayilov	Medium	D-PII, D-CRED	Okta SSO and MFA
SYS-16	Jira and Confluence	Work tracking and documentation	Atlassian SaaS	Tural Mammadli	Medium	D-SRC, D-PII	Okta SSO and MFA
SYS-17	Jamf and Laptop Fleet	Manages 131 laptops (88 enrolled)	Jamf SaaS	Farid Ismayilov	High	D-CRED, D-SRC	Okta SSO; 43 laptops unmanaged
SYS-18	Kyrovia KYC and AML Platform	ID checks, screening, monitoring	Vendor SaaS (EU)	Eglė Norvilaitė	Critical	D-KYC, D-PII, D-PAY	Local accounts with optional MFA
SYS-19	Zendesk Support Desk	Tickets used by Helvora agents	Zendesk SaaS	Mantas Žukas	High	D-PII, D-CHD	Okta for staff; local logins for agents
SYS-20	Tessarin Card Platform	Issuer processing and card vault	Vendor-hosted (EU)	Emin Hasanov	Critical	D-CHD, D-PAY	Vendor portal with MFA; signed API calls

ID	System	Purpose	Hosting	Owner	Criticality	Data	Access reality
SYS-21	Logging Stack	CloudTrail, CloudWatch, OpenSearch	AWS	Rashad Guliyev	High	D-LOG	IAM roles; no SIEM or scheduled review
SYS-22	AWS Backup and RDS Snapshots	Database and storage backups	AWS eu-central-1	Rashad Guliyev	Critical	D-PAY, D-PII	IAM roles; same account as production
SYS-23	Vaskora Bank Connection	SEPA files and safeguarding portal	Bank-hosted; SFTP from AWS	Indrė Sabaliauskaitė	Critical	D-PAY, D-FIN	Bank tokens; SFTP key in Secrets Manager
SYS-24	Metabase Reporting	BI on a production read replica	Self-hosted on EC2	Tomas Butkus	Medium	D-PAY, D-PII	Legacy: local accounts, no MFA
SYS-25	Legacy Jenkins	Runs 7 older deployment jobs	Self-hosted on EC2	Rashad Guliyev	Medium	D-SRC, D-CRED	Legacy: local accounts, no MFA
SYS-26	OpenVPN Bastion	Legacy path to database subnets	Self-hosted on EC2	Rashad Guliyev	High	D-CRED	Legacy: certificate and shared profile, no MFA

6.3 Data classes

ID	Data class	Classification	ID	Data class	Classification
D-PAY	Payment and transaction data	Confidential	D-HR	Employee data	Confidential
D-PII	Customer personal data	Confidential	D-FIN	Corporate financial data	Confidential
D-KYC	Identity documents and KYC files	Restricted	D-SRC	Source code and configuration	Confidential
D-CHD	Cardholder data	Restricted	D-LOG	Security and application logs	Internal
D-CRED	Credentials, keys and secrets	Restricted			

6.4 High-level data flows

ID	From	To	Data	Protection today	Cross-border
DF-01	Merchant systems	Merchant Payment API (SYS-01)	Payment instructions	TLS 1.2+, mTLS, Cloudflare WAF	EU and merchant locations
DF-02	Payment Core (SYS-02)	Vaskora Bank (SYS-23)	SEPA files, statements	SFTP with key authentication	None (EU)
DF-03	Card Program Service (SYS-04)	Tessarin (SYS-20)	Card controls, tokens	Signed API over private link	None (EU)
DF-04	Portal and Orbit (SYS-05, SYS-06)	Kyrovia (SYS-18)	ID files, owner data	TLS API, S3 pre-signed upload	None (EU)
DF-05	Payment Core (SYS-02)	Kyrovia (SYS-18)	Transactions for screening	TLS API with static key	None (EU)
DF-06	Customers	Helvora via Zendesk (SYS-19)	Tickets, identity details	TLS; agent local logins	None (EU)
DF-07	Production (SYS-07, SYS-08)	Baku engineers	Logs, database rows in support cases	AWS SSO, OpenVPN bastion	EU to Azerbaijan (Chapter V GDPR)
DF-08	All AWS accounts	Logging Stack (SYS-21)	Audit and application logs	IAM, encrypted at rest	None (EU)

7 Vendors

Tiers are preliminary, based on data access and business criticality. Project 6 formalizes the criteria. "CIF" marks a vendor that appears to support a critical or important function under DORA, pending legal confirmation.

ID	Vendor	Service	Data access	Tier	CIF
VEN-01	Amazon Web Services	Cloud hosting for all production	Hosts encrypted production data	Tier 1	Yes
VEN-02	Tessarin Card Services S.A.	Issuer processing and card vault	Cardholder and transaction data	Tier 1	Yes
VEN-03	Kyrovia Compliance Ltd	KYC, screening and AML monitoring	Identity documents, transactions	Tier 1	Yes
VEN-04	Vaskora Bank AB	SEPA access and safeguarding accounts	Payment and settlement data	Tier 1	Yes
VEN-05	Helvora Support SIA	Outsourced customer support (Riga)	Customer data via Zendesk and Orbit	Tier 1	Yes
VEN-06	Okta	Workforce SSO and MFA	Staff identity data	Tier 1	Yes
VEN-07	GitHub	Source code and CI/CD	Source code, CI secrets	Tier 1	Yes
VEN-08	Cloudflare	CDN, WAF and DDoS protection	Customer traffic in transit	Tier 1	Yes
VEN-09	Google Workspace	Email and documents	Business and staff data	Tier 2	No
VEN-10	Twilio	SMS for customer alerts and OTP	Phone numbers, message content	Tier 2	No
VEN-11	Zendesk	Support ticketing platform	Customer data in tickets	Tier 2	No
VEN-12	PagerDuty	On-call alerting	Staff contacts, alert metadata	Tier 2	No
VEN-13	Slack	Internal messaging	Business chat, incidental data	Tier 2	No
VEN-14	Atlassian	Jira and Confluence	Project and technical documents	Tier 2	No
VEN-15	Jamf	Laptop device management	Device and user metadata	Tier 2	No
VEN-16	Personio	HR information system	Employee personal data	Tier 2	No
VEN-17	Sentinela Red Team OÜ	Annual penetration testing	Findings, temporary test access	Tier 2	No
VEN-18	Rivenmark Assurance UAB	Co-sourced internal audit	Audit evidence on request	Tier 2	No
VEN-19	Xero	Accounting system	Corporate financial data	Tier 3	No
VEN-20	Caspian Workspace LLC	Baku office and building access	No system access; visitor records	Tier 3	No

8 Regulatory landscape

The table sets out what applies and why. It deliberately omits reporting deadlines and detailed requirements, which Projects 7 and 8 cover and verify. It is a working view, not legal advice.

ID	Driver	Why it matters to Orvanta	Regulator or authority	Owner	Status
REG-01	DORA, Regulation (EU) 2022/2554	Orvanta is a financial entity. Covers ICT risk, incident reporting, resilience testing and ICT third parties.	Bank of Lithuania	Nino Beridze	In force
REG-02	GDPR, Regulation (EU) 2016/679	Controller for customer and staff data. Baku access is a restricted transfer.	State Data Protection Inspectorate	Karolis Vaitkus	In force
REG-03	Payment services rules (PSD2, Directive (EU) 2015/2366, as transposed)	Basis of the payment institution licence, including safeguarding and strong customer authentication.	Bank of Lithuania	Eglė Norvilaitė	In force
REG-04	AML and counter-terrorist financing rules	Customer due diligence, monitoring and suspicious activity reporting.	[verify against official source]	Eglė Norvilaitė	In force

ID	Driver	Why it matters to Orvanta	Regulator or authority	Owner	Status
REG-05	PCI DSS v4.0.1	Contractual through the card program. Vault is outsourced, yet card data has appeared in tickets.	Card schemes through Tessarin	Nino Beridze	Contractual
REG-06	NIS2, Directive (EU) 2022/2555, and Lithuanian Law on Cyber Security	Awareness item. DORA takes precedence for matters it covers, but Baku subsidiary and group scope need legal confirmation.	National Cyber Security Centre (NKSC)	Paulius Grigas	Monitor
REG-07	ISO/IEC 27001:2022 and Amendment 1:2024	Commercial requirement from enterprise merchants, not a legal duty. The amendment adds a climate-change relevance check to clause 4.	Accredited certification body	Nino Beridze	Target

8.1 Verification status

Checked on 7 November 2026. Items marked [verify against official source] could not be confirmed on an official page and need checking before anyone relies on them.

ID	What was checked and the result
REG-01	Verified: EUR-Lex. Art. 2(1)(b) lists payment institutions; Art. 64 sets application from 17 January 2025.
REG-02	Azerbaijan absent from the European Commission adequacy list (checked 2026-11-07). [verify against official source]: Inspectorate role; official site not reachable.
REG-03	Bank of Lithuania site lists its supervision of payment institutions. [verify against official source]: Lithuanian transposing act references.
REG-04	[verify against official source]: competent authority and act references. Context only; outside the portfolio's security scope.
REG-05	Verified: PCI SSC blog. v4.0.1 published June 2024; v4.0 retired 31 December 2024. Orvanta's validation level requires QSA or scheme confirmation.
REG-06	DORA recital 16 (lex specialis) verified on EUR-Lex. [verify against official source]: Lithuanian transposition dates; secondary sources give 18 October 2024.
REG-07	Amendment content confirmed through a national standards body's published copy and certification-body notes.

9 Current security maturity

The average indicative score is 1.6 out of 5. This is an intake view from interviews and a light document review, not a formal assessment. Project 1 replaces it with a control-by-control score against clauses 4 to 10 and all 93 Annex A controls.

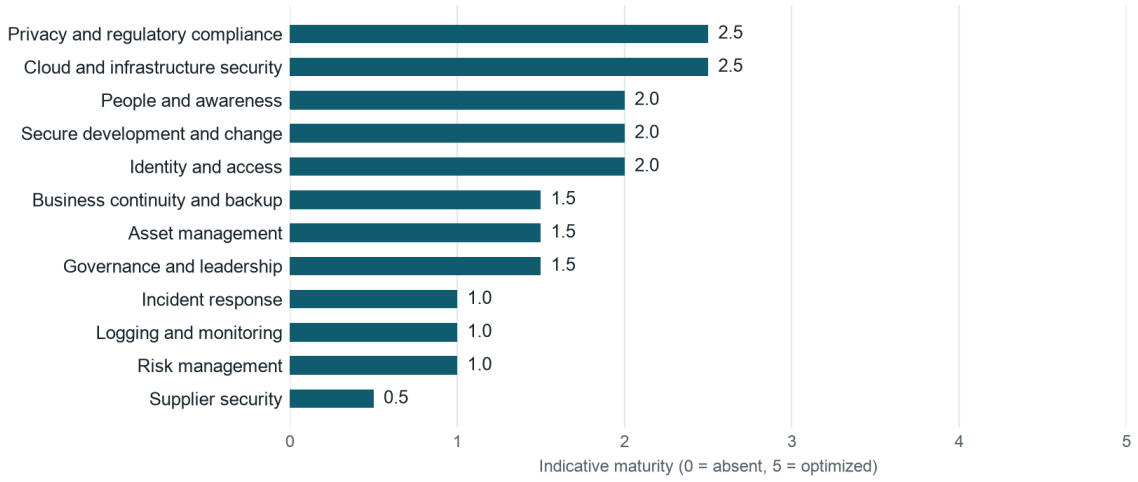


Figure 3: Indicative maturity by security domain, highest at the top.

9.1 Baseline observations and the attacker's view

Each observation is paired with how an attacker would use it, because a gap matters most when it opens a real attack path.

ID	Area	What we observed	How an attacker would use it	Owner
OBS-01	Risk management	Risk register is one spreadsheet, last updated February 2025, with no criteria or owners.	Nobody has asked which path to the ledger is the easiest, so nobody has closed it.	Lukas Jankauskas
OBS-02	Privileged access	Shared admin accounts remain in the AWS legacy account, Orbit and the DBA credential.	One stolen shared password gives high privilege with no named person in the logs.	Rashad Guliyev
OBS-03	Offboarding	Last 18 leavers: median removal 9 days, worst case 37 days.	A former engineer may keep working credentials for weeks.	Farid Ismayilov
OBS-04	MFA coverage	Okta apps have MFA. Metabase, Jenkins, OpenVPN, Kyrovia and agent Zendesk logins do not enforce it.	Phishing and credential stuffing go straight to the tools Okta does not guard.	Farid Ismayilov
OBS-05	Backup and recovery	Daily backups run, but no full restore is on record. Backups share the production account.	Ransomware operators with account access can delete backups before encrypting data.	Rashad Guliyev
OBS-06	Supplier security	0 of 20 vendors have a documented security assessment. No DORA register is complete.	The weakest supplier with customer data becomes the easiest way in.	Eglė Norvilaitė
OBS-07	Logging and detection	CloudTrail is off in 1 of 5 AWS accounts. There is no SIEM and no scheduled log review.	An intruder can stay in the environment because no one is looking.	Nino Beridze
OBS-08	Incident response	Draft plan dates from 2023. It has no regulatory timelines and has never been exercised.	Confusion in the first hours gives attackers time to escalate and reporting clocks run.	Nino Beridze
OBS-09	Change control	Branch protection covers 61% of repositories. 14% of Q3 2026 production deployments bypassed review.	A compromised developer account can ship malicious code to production unreviewed.	Tural Mammadli
OBS-10	Card data handling	A March 2026 search found 11 Zendesk tickets containing full card numbers pasted by customers.	A local agent login opens a searchable store of card numbers.	Mantas Žukas
OBS-11	International transfers	Baku engineers can view production personal data. No documented transfer impact assessment exists.	Broad remote production access widens the blast radius of any stolen laptop session.	Karolis Vaitkus
OBS-12	Security governance	The CISO-designate, hired in September 2026, reports to the CTO, whose teams own most gaps.	Risks that slow delivery can be deprioritized before they reach the board.	Ugnė Baltrūnaitė